Documentation Quality Compliance Checker

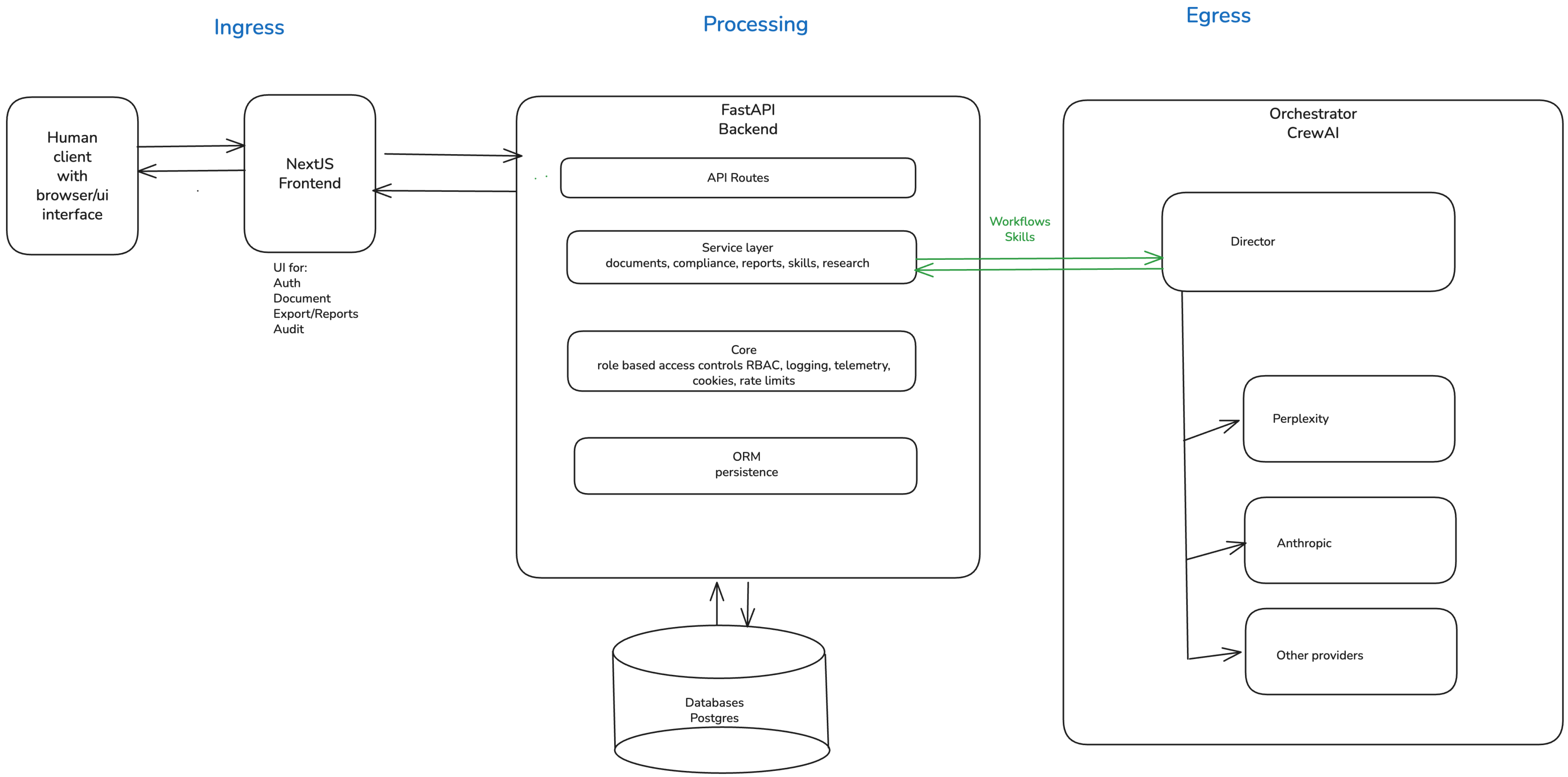
Ilona Brinkmeier
Wiebke Meyer
Carol Willing

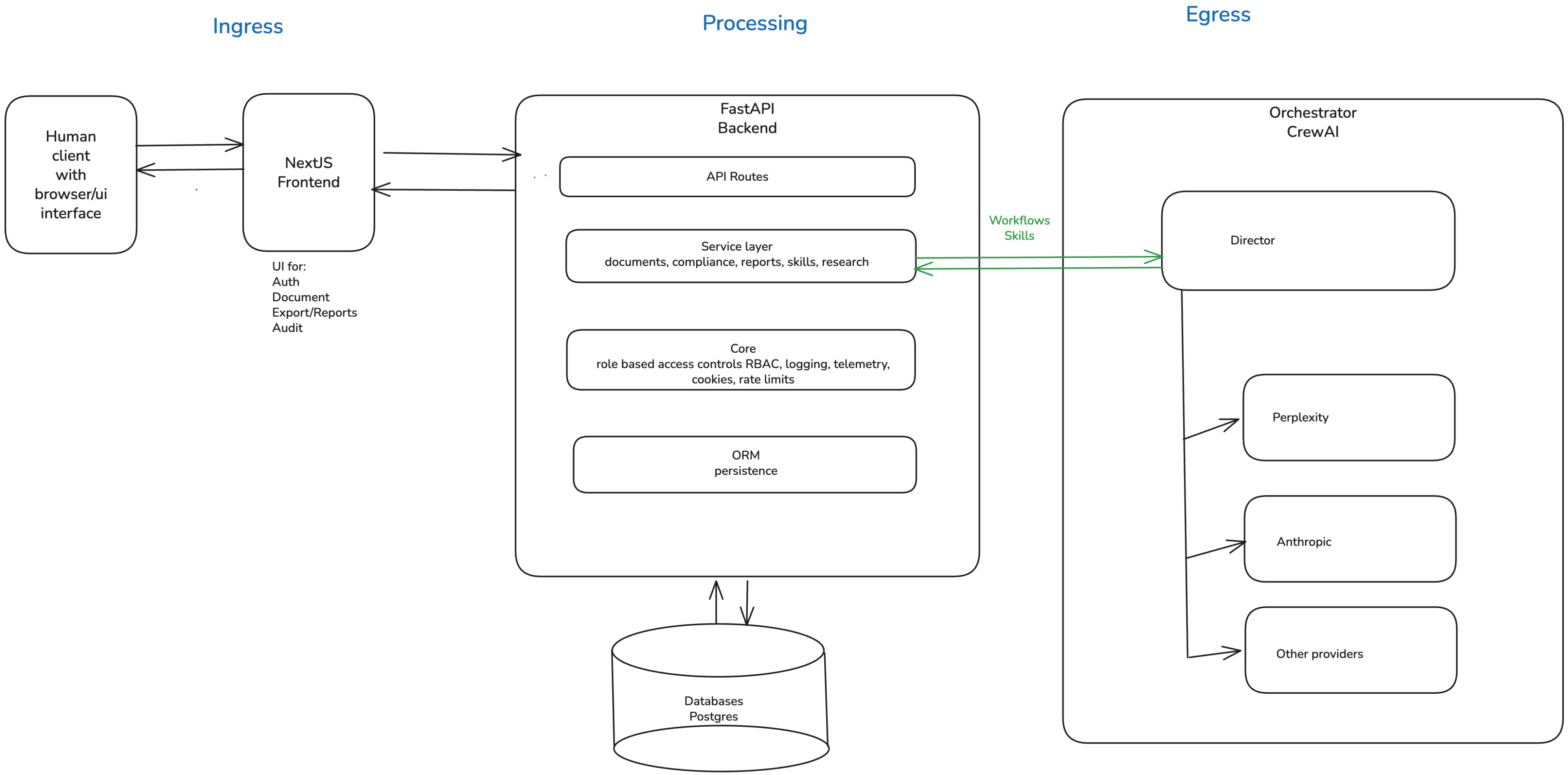
Real-world problem

Develop an efficient, accurate software system to review technical documents

- audit document quality
- measure compliance with legal standards
- submit results to external agencies
- ensure the automation's behavior and provide human oversight

The present solution




Ingress
Processing
Egress
Human client with browser/ui interface
NextJS Frontend
UI for:
Auth
Document
Export/Reports
Audit
FastAPI Backend
API Routes
Service layer
documents, compliance, reports, skills, research
Core
role based access controls RBAC, logging, telemetry, cookies, rate limits
ORM
persistence
Databases
Postgres
Workflows
Skills
Orchestrator CrewAI
Director
Perplexity
Anthropic
Other providers

Why privacy matters

Insert brief list of why privacy matters

2.

Privacy risks

2.0

Top privacy risks

1. Egress traffic flow data to orchestrator and models
2. Application telemetry and workflow tracing
3. Role-based access controls and GDPR compliance

2.1 Risk Area 1

Egress traffic flow data to orchestrator and models

Sensitive data:

- External model: transfer of potentially personal prompt/output data
  - **Data**:
    - Names, emails, stakeholder assignments, reviewer identifiers, document passages copied into prompts, generated summaries that may restate personal data
  - **Why Sensitive**:
    - Leaves the primary application context during model inference (current external-provider path)

- Over-collection and -retention in model observability traces
    - **Data**:
        - provider, model_used, trace_id, correlation_id, latency/tokens, rich payload entries, prompt/output snapshots
    - **Why Sensitive**:
        - Enables reconstruction of *who* triggered *what* model action and *when*
        - can become re-identifiable when combined with audit tables

- Model credentials and routing configuration
    - **Data**:
        - API keys, adapter routing flags, provider selection settings
    - **Why Sensitive**:
        - Compromise enables data exfiltration or unauthorized model usage

2.2 **Risk Area 2**

Application telemetry and workflow tracing

Sensitive data:

- Raw LLM promp and output in *quality_observations.payload*
  - **Data**:
    - *payload.provider, payload.model_used, payload.llm_temperature*
    - *payload.llm_prompt* (document text submitted by user, stakeholder names, reviewer assignments)
    - *payload.llm_output* (generated compliance summaries restating personal context)

- - **Why Sensitive**:
    - Prompt context is assembled from user-submitted documents which routinely
      contain names, emails, project identifiers, and business-sensitive content
    - The output may restate or summarise that content
    - Both are persisted to a queryable table

- Audit event payload in audits_events.payload
  - **Data**:
    - payload.roles (user role at login), payload.remember_me flag, event-specific context fields, any free-form data inserted by orchestrator or Skills API callers
  - **Why Sensitive**:
    - Append-only and intended for long retention
    - No technical control prevents a caller from writing personal data into the payload column
    - Combined with actor_id (user email) it forms a rich personal profile

Risk Area 2

- OTEL (open telemetry) span attributes (exporter config)
  - **Data**:
    - HTTP path attribute (e.g., */api/v1/documents/doc-abc123* — document ID in path), user_agent, http.method, http.status_code, trace_id / span_id (linkable back to session)
  - **Why Sensitive**:
    - When TRACING_EXPORTER=otlp span data is sent to an external collector,
      - path values can embed document or session identifiers
      - user-agent can contribute to fingerprinting

Risk Area 2

- Frontend CSV export of prompt/output pairs
  - **Data**:
    - Exported observability *prompt_output_pairs.csv* file containing prompt, output, source_component, trace_id, timestamps
  - **Why Sensitive**:
    - Created on the user's local filesystem;
    - outside system access controls, retention policy, and audit log;
    - may contain personal data from documents processed during the export window

2.3 Risk Area 3

Role-based access controls and GDPR compliance

Sensitive data:

- User identity in session store
  - **Data**:
    - user_email (primary identifier), user_org, session session_id, expires_at, last_seen_at
  - **Why Sensitive**:
    - Directly identifies users and links their organisational role to access patterns and audit trails
    - Retained in PostgreSQL with no visible TTL-based purge policy

- Role assignments and permission scope
  - **Data**:
    - user_roles array per session row (e.g., ["qm_lead"], ["auditor"]), org isolation field user_org
  - **Why Sensitive**:
    - Reveals organisational responsibilities and access privileges
    - Can be used for social engineering or targeted attacks
    - GDPR data minimisation applies

- Bootstrap/MVP credentials in environment configuration
  - **Data**:
    - AUTH_MVP_EMAIL, AUTH_MVP_PASSWORD, AUTH_MVP_ROLES, AUTH_MVP_ORG (env vars)
    - SECRET_KEY (API key secret)
  - **Why sensitive**:
    - Compromise of bootstrap credentials gives attacker a fully provisioned account with configurable roles
    - SECRET_KEY grants service-client access to skills and observability

- Access decision and audit context not separately persisted
  - **Data**:
    - Which role accessed which route at what time
    - 403 access denials
    - service-client route usage with payload summary
  - **Why sensitive**:
    - Absence of access-decision audit log prevents retrospective investigation of data-access incidents
    - Required for GDPR Art. 30 record of processing activities and breach response

3.

Mitigations and controls

3.0

Mitigations and controls

- Mitigation implemented
- Technical details
- Selected approach vs. alternatives
- Outcome and learnings

3.1 Mitigating Risk 1

Egress traffic flow data to orchestrator and models

3.2 Mitigating Risk 2

Application telemetry and workflow tracing

3.3 Mitigating Risk 3

Role-based access controls and GDPR compliance

Recommendations

Top priority

- Insert what it is
- Insert why it is important
- Insert why it matters to company and risk strategy
- Insert what value does it create

Questions

Audit

https://willingc.github.io/compliance-checker

by Ilona, Wiebke, Carol